AI 智能体创新应用挑战赛 · 答辩汇报

AI 银行管家

用户说一句，Agent 把业务办完

可授权 · 可审计 · 可回退的银行级智能体

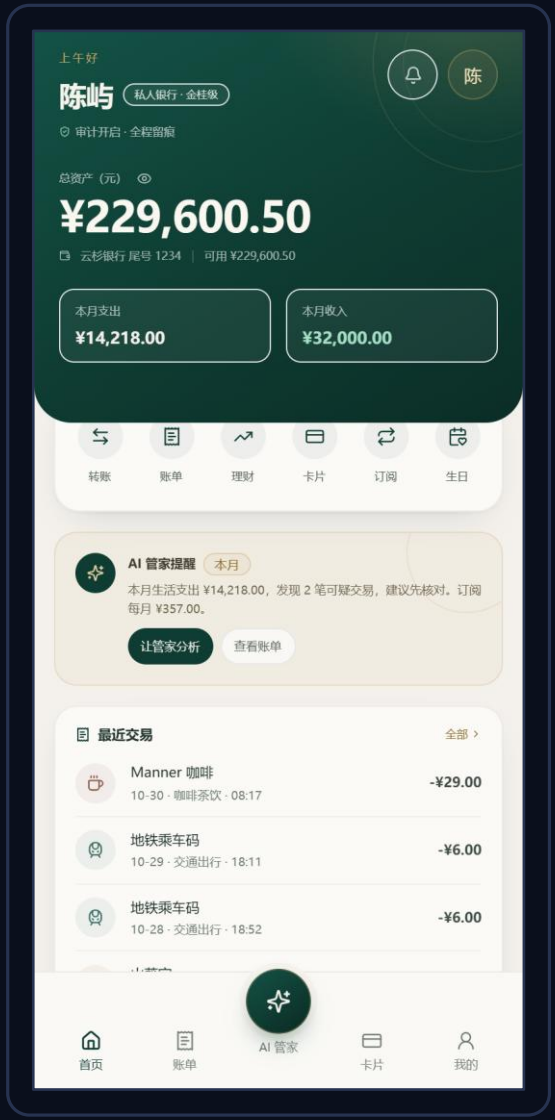
01 六大场景 转账 / 账单 / 理财 / 卡片 / 订阅 / 跨场景联动

02 三级权限 日累计 1000 元分界，5 万元硬阻断

03 四项安全 防幻觉 · 防注入 · 哈希链审计 · 熔断沙箱

04 真实执行 计划任务到点扣款，语音与生物识别真实可用

汇报人 _____ · 日期 _____ · 在线体验与仓库地址见末页



把权限、审计、回退做进执行骨架

对标：赛题背景 / 产品形态

银行 Agent 的四个信任缺口

- **越权不可控** 模型输出直接驱动操作，提示词即权限
- **幻觉出数字** 余额、收益率由语言层生成
- **注入可诱导** 一句绕过话术跳过确认
- **事后无留痕** 无法还原谁批准了什么

我们的做法 权限判定、授权签发、审计留痕、补偿回退全部放在服务端执行层，模型只负责理解意图。

体验问题（入口深、术语多、无上下文）交给对话式入口；信任问题交给执行层。

/console 评委控制台与手机端读同一份服务端状态，链路当场可查。



对话内完成确认与强验证



账号 · 额度 · 测评 · 设备



调度结果与提醒中心

六大场景全部落到一次真实操作

对标：赛题任务六大场景

01

智能转账

“给林晚转 520 元，备注爱你”

同名先澄清 · 定时到点扣款 · 拆分 AA · 当日冲正

02

账单分析

“这个月花了多少？有异常吗”

分类由流水推导 · 环比 · 重复扣费与异常识别

03

理财操作

“想放一万，推荐款稳健的”

风险测评 → 适当性上限 → 对比 → 申购走红色

04

卡片管理

“申请一张虚拟卡，额度 3000”

额度总览 · 申请注销 · 冻结解挂（挂失为红色）

05

订阅 / 代扣

“把健身会员的自动续费取消”

识别订阅与涨价 · 续费提醒 · 取消可恢复

06

跨场景联动

“我爱人下周生日，帮我提前安排”

预算锁定 + 两笔订购 + 日程，一张确认单

风险测评 决定可购产品上限

交易详情 可提交争议工单

服务端调度 到点真实执行

账号体系 验证 / 找回 / 踢设备

档位由服务端按账本判定

对标：核心技术要求 · 权限分级

档位	判定条件	执行策略	本系统实例
绿色	查询类，不动钱	确认意图后自动执行	余额与账户查询、交易记录、账单分析、持仓与收益、订阅扫描
黄色	小额资金 / 可逆配置	用户确认，不二次强验	日累计 ≤1000 元转账、取消订阅、虚拟卡申请、额度调整、卡片冻结、生日联动的预算与订购
红色	大额或不可逆	多因子强验证后执行	日累计 >1000 元、理财申购与赎回、卡片挂失解挂；单笔 >5000 元升级双因子

判定输入全部取自账本

- 金额
- 当日已用额度
- 操作类型
- 会话风险状态

模型输出里写“这是小额”，档位不变。

硬阻断 5 万元以上直接拒绝并留痕，任何授权都越不过；额度台账预约 / 提交两阶段，防止并发把日累计绕过去。

双因子 单笔 >5000 元在强验证之上再要求第二因子；短信由服务端下发后再校验，客户端自行标记“已通过”在真实通道下无效。

差异声明 密码修改走原密码校验 + 服务端会话 + 其他设备全部下线，未纳入 Agent 的红色操作目录；U 盾未接入。

确认单是哈希锁定的参数摘要

对标：多因子认证 + 操作确认

1 摘要哈希绑定
用户 + 会话 + run + 节点 + 全部参数

2 展示与确认
收款人 / 金额 / 账户 / 备注 / 剩余额度

3 签发一次性授权
90 秒过期，用后即废

4 执行前重校验
参数被改或风险升级 → 作废重验

摘要覆盖什么

- 哈希绑定：用户、会话、run、节点、全部参数
- 人可读：收款人、金额、账户、备注、当日剩余额度
- 失效即重来：期间被篡改 → 旧授权作废并重新要求验证

红色操作可用三条通道

- **本机生物识别** WebAuthn 平台认证器，服务端校验 origin、rpId、一次性挑战与签名计数器
- **签约活体人脸** HTTP Provider，未签约时退回演示通道并显式标注
- **短信验证码** 服务端下发、一次性随机码，用后即删

批量确认逐个授权 跨场景联动的一张确认单覆盖三个操作，每个节点仍有独立 grant、独立 digest，执行前逐个校验。

回退分两种 可逆节点按逆序补偿（冲正、解冻、恢复订阅）；申购与挂失不可逆，界面显示“部分完成 · 转人工”。

四道防线，越往里越不依赖模型

对标：核心技术要求 · 安全机制

① 幻觉防护
事实锁定

模型只输出受 JSON Schema 约束的意图与槽位，不生成执行计划、不产出金额、不写回执文案；账户、余额、收益率一律取自账本。渲染前数字守卫扫描输出中的金额与百分比，与账本不一致则整段拒绝下发。

② 注入防御
三层递进

输入侧规则打分（越权指令、绕过话术、系统提示探测）→ 模型侧嫌疑度升级 → 服务端策略、授权与工具白名单兜底。语言层被骗过时，工具目录里没有的路径依然执行不了。

③ 操作审计
追加式哈希链

userId 参与哈希，逐条记录意图解析、策略判定、授权签发、节点执行、补偿与人工介入，每 50 条 checkpoint；支持按用户过滤、按 run 回放，篡改副本链会被检出。

④ 熔断与沙箱
失败即关闭

连续工具失败或连续注入命中即锁定会话，必须人工复核解锁，解锁动作本身入链。模型生成的统计代码在 worker + vm 内运行，先静态检查再执行，无文件与网络权限，带超时与内存上限，输入只来自当前用户的只读快照。

现场可验证：攻防实验室里摘要篡改、令牌重放、策略独立性三项均可当场发起，并看到拦截与审计留痕。

固定任务图 + 拓扑执行

对标：核心技术要求 · 意图理解与任务规划

“我爱人下周生日，帮我提前安排”

未被显式要求转账或下单 → 识别为跨场景规划任务 → 生成可确认的方案



一张确认单覆盖三个黄色操作：一次批准、分别授权、分别留痕。

预算到期由服务端调度器自动释放，订购到点由调度器真实下单。

规划的四个约束

- **执行图由意图决定** 每个意图对应预置任务图（解析→校验→执行→渲染），工具白名单随之锁定，模型无法扩展自己的权限边界
- **槽位缺失先澄清** 金额、收款人、产品为空时不默认填值，不带着空收款人执行资金操作
- **上下文可接住省略** “再转 200” “就那个” “换成 1000”由上下文栈解析
- **执行可控可恢复** 待确认可取消、执行中可中断、人工可接管；确认即断流，按 seq 续传

回退分两种 转账冲正、解冻、订阅恢复走补偿；申购与挂失不可逆，只标记转人工，界面显示“部分完成”。

确认时主动断流 SSE 不挂起等待人工，run.paused 后关闭连接，确认后用序号续传；刷新页面从快照恢复同一张确认单。

同一份服务端状态，当场可查

本页切换实机演示

1 **黄色 · 小额转账** “给林晚转 520 元，备注爱你”

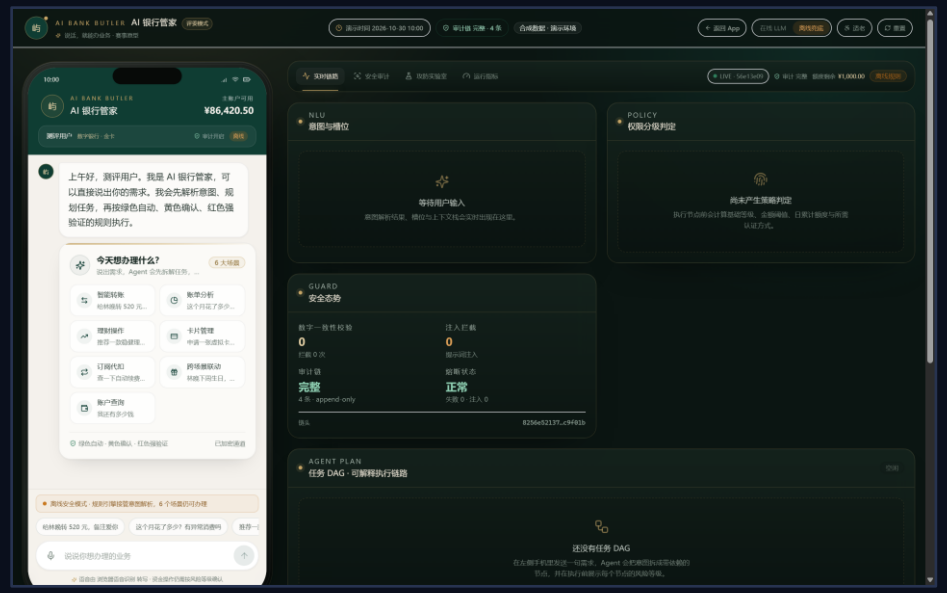
控制台看 NLU 槽位 → DAG 三节点 → 策略判黄 → 摘要哈希 → 确认后审计链增长

2 **红色 · 当日累计越线** “再给林晚转 6000 元”

当日累计已过 1000，档位升红；走本机生物识别签名（服务端验签）或双因子

3 **注入 · 熔断 · 接管** 绕过确认 / 系统提示探测话术

INJECTION_BLOCK 入链；第二条命中即锁会话，人工复核解锁且解锁动作本身入链



评委控制台：意图解析、任务图、策略判定、授权摘要、审计链、攻防实验室同屏

三笔共用同一份当日额度台账 第 2 笔变红，正是第 1 笔造成的。

兜底 链路不稳时切“离线兜底”，规则引擎跑完六个场景；模型不可用时控制台标注 offline 来源；确认单 90 秒过期，取消后重发。

每条主张都能复现，接真实核心只换配置

对标：项目规范 · 可交付性

105
项单元测试
策略 / NLU / 规划 / 审计 / 账本 / 集成 / 风险 / 争议

236
条审计事件
全链路冒烟一次跑完的真实留痕

33
项浏览器回归
真实 Chrome：确认、强验、工单、语音、响应式

291
个第三方依赖
许可逐条清点（MIT / ISC / Apache / BSD 等）

两种运行形态：纯产品版与带标注版只差一个构建期开关，行为与数据来源完全一致。

BankingGateway 抽象
快照读取 + 操作写入

仿真核心
本地确定性数据，开箱即演示

HTTP 签名网关
HMAC-SHA256（方法+路径+时间戳+nonce+报文哈希）· 写操作幂等键 · 超时重试 · 客户端熔断 · Schema 校验

失败即关闭
真实模式同步失败直接返回不可用，绝不回退仿真数据；接入配置不完整时服务启动即失败。

对外契约齐备：OpenAPI 接口定义、字段与错误码、幂等语义、联调桩；行方按契约映射到自有核心即可，两种模式共用同一套工具、策略与审计代码。

已具备的能力，和还没做的事

自评口径：开发期自查

已具备（今天可演示）

六大场景闭环 · 三级权限判定

一次性授权摘要 · 多因子强验证

追加式哈希链审计 · 异常熔断与人工接管

受限代码沙箱 · 适当性拦截申购

争议工单受理 · 服务端真实调度

可安装 PWA + 多用户隔离 · 评委控制台

未做（生产化阶段）

- 行方凭据：真实账户读写、短信模板、活体人脸、语音转写：交付契约与可切换实现，未做行方联调
- 账号与风控：无 U 盾、无 KYC 与账号注销；风控覆盖金额阈值与频次限流，缺商户/设备/地区/黑名单维度
- 渠道：IM 渠道未接入；对话接口与渠道无关，接入只需增加消息适配层
- 生产化：存储为单机 JSON、会话在内存；争议只到受理与状态回显；未做渗透测试与第三方安全评估

我们交付判断，也交付边界。 演示通道在界面上如实标注性质；凭据类能力交付契约、可切换实现与失败即关闭的行为。

源代码仓库

GitHub 地址待填写（仓库尚未初始化）

在线体验

https://theology-confirmed-ban-hay.trycloudflare.com

演示视频

≤5 分钟，分镜已就绪，待录制

让 Agent 能办事不难，难的是敢让它办事：每一分钱都能说清是谁、在什么授权下、经哪条链路动的。